



OPEN
Compute Project

Security Project

OCP Composite EAT Profile for Platform Inventory Attestation

0.8.0

Modular Design Specification
Effective September 10, 2026

Author: Xiling Sun (Microsoft)
Author: Roksana Golizadeh Mojarad (Microsoft)
Author: Raghu Krishnamurthy (NVIDIA)

Table of Contents

1	License	5
1.1	Open Web Foundation (OWF) CLA	5
2	Copyright / Trademark	6
3	Compliance with OCP Tenets	8
3.1	Openness	8
3.2	Efficiency	8
3.3	Impact	8
3.4	Scale	8
3.5	Sustainability	8
4	Introduction	9
4.1	Problem Statement	9
4.2	Approach	9
4.3	Scope	9
5	Conventions and Terminology	11
6	Architecture and Trust Model	12
6.1	Composite Device Architecture and Trust Boundaries	12
6.2	Delegated Collection and Bundle-Assembly Functions	12
6.3	Threat Model	12
6.4	Security Properties and Limits	13
7	Composite EAT Profile	14
7.1	Profile Identifier	14
7.2	Profile Conformance	14
7.3	Bundle Structure	15
7.4	Top-Level Claims	16
7.5	Lead Attester Self-Measurements	16
8	Detached Sub-Attester Evidence	17
8.1	Detached-Submodule-Digest Binding	17
8.2	Deterministic Encoding and Digest Rules	17
8.3	Native Evidence Carriage	17
8.3.1	SPDM Signed Measurements	18
8.3.2	Device-Emitted EAT	18
8.3.3	Recursive Composite EAT	18
8.3.4	SPDM-Carried TCG DICE Concise Evidence	19
8.3.5	CMW and Digest Boundaries	19
8.4	Target Environment Identifier	19
9	Verification (Informative)	20
10	Security Considerations	21
10.1	Native Evidence Protection	21
10.2	Lead Attester Protection	21
10.3	Resource Exhaustion	21
11	Privacy Considerations	22

12 IANA Considerations 23

13 Alignment and Change Control..... 24

14 Acknowledgements 25

Appendices 26

A Worked Example 26

B Collected CDDL 29

References 31

List of Tables

1 Composite EAT profile conformance 14

1 License

1.1 Open Web Foundation (OWF) CLA

Contributions to this Specification are made under the terms and conditions set forth in **Modified Open Web Foundation Agreement 0.9 (OWFa 0.9)**. (As of October 16, 2024) (“Contribution License”) by:

- Microsoft Corporation

Usage of this Specification is governed by the terms and conditions set forth in **Modified OWFa 0.9 Final Specification Agreement (FSA)** (As of October 16, 2024) (“**Specification License**”).

You can review the applicable Specification License(s) referenced above by the contributors to this Specification on the OCP website at <https://www.opencompute.org/contributions/templates-agreements>.

For actual executed copies of either agreement, please contact OCP directly.

NOTWITHSTANDING THE FOREGOING LICENSES, THIS SPECIFICATION IS PROVIDED BY OCP “AS IS” AND OCP EXPRESSLY DISCLAIMS ANY WARRANTIES (EXPRESS, IMPLIED, OR OTHERWISE), INCLUDING IMPLIED WARRANTIES OF MERCHANTABILITY, NON-INFRINGEMENT, FITNESS FOR A PARTICULAR PURPOSE, OR TITLE, RELATED TO THE SPECIFICATION. NOTICE IS HEREBY GIVEN, THAT OTHER RIGHTS NOT GRANTED AS SET FORTH ABOVE, INCLUDING WITHOUT LIMITATION, RIGHTS OF THIRD PARTIES WHO DID NOT EXECUTE THE ABOVE LICENSES, MAY BE IMPLICATED BY THE IMPLEMENTATION OF OR COMPLIANCE WITH THIS SPECIFICATION. OCP IS NOT RESPONSIBLE FOR IDENTIFYING RIGHTS FOR WHICH A LICENSE MAY BE REQUIRED IN ORDER TO IMPLEMENT THIS SPECIFICATION. THE ENTIRE RISK AS TO IMPLEMENTING OR OTHERWISE USING THE SPECIFICATION IS ASSUMED BY YOU. IN NO EVENT WILL OCP BE LIABLE TO YOU FOR ANY MONETARY DAMAGES WITH RESPECT TO ANY CLAIMS RELATED TO, OR ARISING OUT OF YOUR USE OF THIS SPECIFICATION, INCLUDING BUT NOT LIMITED TO ANY LIABILITY FOR LOST PROFITS OR ANY CONSEQUENTIAL, INCIDENTAL, INDIRECT, SPECIAL OR PUNITIVE DAMAGES OF ANY CHARACTER FROM ANY CAUSES OF ACTION OF ANY KIND WITH RESPECT TO THIS SPECIFICATION, WHETHER BASED ON BREACH OF CONTRACT, TORT (INCLUDING NEGLIGENCE), OR OTHERWISE, AND EVEN IF OCP HAS BEEN ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

2 Copyright / Trademark

Names and brands mentioned may be claimed as trademarks by their respective owners. IETF is a registered trademark of IETF Trust.

Revision History

Revision	Date	Author(s)	Description
0.8.0	2026-09-10	Xiling Sun (Microsoft) Roksana Golizadeh Mojarad (Microsoft) Raghu Krishnamurthy (NVIDIA)	Initial draft for OCP project review

3 Compliance with OCP Tenets

3.1 Openness

This profile uses publicly specified evidence formats and enables interoperable verification across platform and device vendors.

3.2 Efficiency

This profile combines platform and device evidence into one artifact while preserving native device evidence, reducing repeated external collection and format-conversion operations.

3.3 Impact

This profile provides a common method for conveying platform inventory attestation evidence from heterogeneous devices.

3.4 Scale

This profile supports flat and recursive platform composition and uses detached evidence to accommodate platforms containing multiple independently attesting devices.

3.5 Sustainability

This profile reuses existing EAT, CWT, COSE, CMW, and native device evidence formats, enabling incremental adoption without replacing existing device attestation implementations.

4 Introduction

4.1 Problem Statement

Platform attestation today is commonly disaggregated. Where per-device Evidence is retrieved independently, attesting a whole platform requires separate transactions that return independently protected responses. The Verifier must then reconstruct the relationship between those components, the encompassing platform, and the freshness challenge. There is no single signed, platform-scoped artifact that binds a Verifier nonce, the Lead Attester state, and the reported Sub-Attester Evidence set.

Four gaps follow:

1. No aggregate. The Verifier reassembles the composite system from independent evidence artifacts.
2. No uniform carriage. Sub-Attesters may expose SPDМ signed measurements, emit their own signed EAT, or themselves produce a Composite EAT. A common structure is needed without rewriting the protected native evidence.
3. Lead Attester overhead. Requiring the Lead Attester to implement every Sub-Attester protocol solely to describe itself increases trusted-computing base size and complexity.
4. External orchestration. Retrieving and correlating Evidence independently from every component requires repeated externally visible operations and exposes internal topology and transport details to the Verifier.

4.2 Approach

A Lead Attester, following the composite-device pattern in Section 3.3 of [1], produces one signed Composite EAT. The token carries the Lead Attester's measurements and, for every Sub-Attester, a detached-submodule digest that commits to its evidence. Native evidence is preserved and conveyed in CMW Records under CWT claim 299 in detached Claims-Sets within a Detached EAT Bundle (CBOR tag 602, [2]).

The signed digests bind the detached Claims-Sets. Native signatures preserve the provenance of each Sub-Attester Evidence item. Evidence collection and bundle assembly MAY be performed outside the Lead Attester without granting those functions authority to produce or appraise native Evidence.

The resulting bundle provides one platform-scoped artifact for a collection event. The signed main token binds the Lead Attester identity, Lead Attester measurements, freshness challenge, reported Target Environment Identifiers, and digests of the included detached Claims-Sets. This reduces external collection transactions and topology-dependent orchestration while preserving native Evidence provenance. It does not replace native Evidence validation or appraisal against independently trusted expected-composition information.

4.3 Scope

This document specifies the Composite EAT evidence format for platform inventory attestation: the signed main token, detached native-Evidence carriage, digest binding, processing rules, and supported Evidence forms. It supports flat and recursive platform composition.

Appraisal against composition endorsements and reference values is described informatively and specified by deployment policy. Transport APIs, physical connector locality, bus-level anti-relay guarantees, trust-anchor enrollment, and endorsement authoring are outside scope.

Workload attestation, tenant attestation, confidential-computing device assignment, and Trusted Device Interface Security Protocol (TDISP) device attachment are outside the scope of this profile.

5 Conventions and Terminology

The key words “MUST”, “MUST NOT”, “REQUIRED”, “SHALL”, “SHALL NOT”, “SHOULD”, “SHOULD NOT”, “RECOMMENDED”, “NOT RECOMMENDED”, “MAY”, and “OPTIONAL” in this document are to be interpreted as described in BCP 14 [3] [4] when, and only when, they appear in all capitals.

Data structures are defined using the Concise Data Definition Language (CDDL) [5].

This document uses Attester, Verifier, Relying Party, Endorser, Reference Value Provider, Lead Attester, Sub-Attester, Composite Device, Target Environment, and Attesting Environment as defined in [1].

Detached Claims-Set: The native Sub-Attester evidence for one Target Environment, encoded as a CBOR Claims-Set and conveyed in the detached slot of the Detached EAT Bundle. A digest in the signed Composite EAT commits to it.

Target Environment Identifier: A stable topology label rendered as an `env.*` string and used as the map key for a Sub-Attester in both the signed submods claim and detached Claims-Set map.

6 Architecture and Trust Model

6.1 Composite Device Architecture and Trust Boundaries

This profile applies the RFC 9334 composite-device pattern. The Lead Attester constructs and signs the main token, including the nonce, its identity and measurements, the reported Target Environment Identifiers, and the detached Claims-Set digests. The Lead Attester does not appear in submods; its claims are top-level claims.

Sub-Attesters produce independently protected native Evidence. The Lead Attester signature does not make the Lead Attester authoritative for that Evidence. The Verifier validates the Composite EAT signature and each Sub-Attester's native protection, then appraises the reported composition using independently trusted expected-composition information supplied by an Endorser, Reference Value Provider, or other source authorized by Verifier policy.

In a BMC-mediated implementation, the Lead Attester can be a Root of Trust associated with the BMC. The BMC RoT protects the Composite EAT signing key, supplies the Lead Attester identity and local measurements, and produces the signed main token.

6.2 Delegated Collection and Bundle-Assembly Functions

Evidence collection and bundle assembly are implementation functions that MAY be delegated to one or more supporting components, either within or outside the Lead Attester's protected boundary. These functions may discover Sub-Attesters, obtain native Evidence, construct detached Claims-Sets, and assemble or convey the final bundle. In a BMC-mediated implementation, BMC software commonly performs these functions outside the BMC RoT's protected signing boundary.

Delegation does not transfer Lead Attester authority. Supporting components may supply the nonce, reported Target Environment Identifiers, and detached Claims-Set digest records as inputs, and may combine the signed main token with the detached Claims-Sets. They cannot produce the Lead Attester signature and are not authoritative for native Evidence authenticity, collection completeness, or Target Environment Identifier correctness.

A collection implementation SHOULD use an authenticated collection policy, or an equivalent trusted mechanism, to mitigate the risk of accidental or malicious omission during Evidence collection. Such hardening improves collection coverage and integrity. It does not establish platform-inventory completeness or make the collection implementation authoritative for expected platform composition.

6.3 Threat Model

Threat	Mitigation or detection
Main-token forgery	Validate the COSE_Sign1 signature and Lead Attester certificate path.
Lead Attester certificate misbinding	Match protected x5t to the end-entity certificate in x5chain.
Composite EAT replay	Match eat_nonce to the Verifier challenge.

(continued on next page)

(continued from previous page)

Threat	Mitigation or detection
Detached Claims-Set modification	Recompute the digest committed to by the signed submods entry.
Fabricated native Evidence	Validate the Sub-Attester's native signature or other protection.
Native Evidence replay	Verify that the native Evidence binds the same nonce.
Omission from one bundle map	Require identical submods and detached Claims-Set key sets.
Omission from both maps	Compare the reported environment set with independently trusted expected-composition information.
Target Environment Identifier mislabeling	Compare the proven native identity with the identity authorized for that environment.
Expected-composition substitution	Authenticate and authorize the expected-composition source according to Verifier policy.
Lead Attester compromise	Treat the platform-scoped binding as compromised; independently protected Sub-Attester Evidence still requires separate validation.

6.4 Security Properties and Limits

The Composite EAT signature establishes integrity and freshness of the included platform observation. It does not independently establish platform-inventory completeness, Target Environment Identifier correctness, physical locality, or protection against bus-level relay. Those properties require Verifier appraisal against independently trusted expected-composition information and, where applicable, additional transport or hardware assurances.

7 Composite EAT Profile

7.1 Profile Identifier

This specification requests OCP assignment of 1.3.6.1.4.1.42623.1.4 to the OCP Composite EAT profile. Version 0.8.0 otherwise defines the implementation-complete wire format. Assignment is requested now so that producer and Verifier implementations do not assume an unapproved identifier. Until OCP confirms it, implementations **MUST NOT** treat this value as assigned.

After approval, claim 265 **MUST** contain the assigned absolute OID encoded without a CBOR OID tag, as required by [2]. For the requested value, the claim value is h'2b0601040182cc7f0104' using the encoding defined by [6]. Final IETF references and registration status will be reconciled before version 1.0.0; any wire-incompatible change requires a new profile identifier.

The OID 1.3.6.1.4.1.42623.1.3 identifies the OCP Profile for IETF Entity Attestation Token and **MUST NOT** be used as the profile identifier of the Composite EAT main token. A device-emitted EAT carried as Sub-Attester Evidence **MUST** conform to the OCP Profile for IETF Entity Attestation Token and identify that profile in its own eat_profile claim. This requirement does not require a Sub-Attester that supplies native SPDM Evidence to emit an EAT.

7.2 Profile Conformance

This section resolves the profile items in Section 6 of [2].

Table 1: Composite EAT profile conformance

Profile item	This profile
Profile identifier	Requested OID 1.3.6.1.4.1.42623.1.4; pending OCP approval
Serialization	CBOR satisfying the core deterministic encoding requirements of Section 4.2.1 of [7]
Top-level message	Detached EAT Bundle with tag 602 [2]
Top-level media type	application/eat-bun+cbor [8]
Main token	CWT tag 61 containing COSE_Sign1 tag 18
Token protection	Exactly one COSE_Sign1 [9] using ES384, algorithm -35 [10]; MAC and encryption structures are prohibited
Detached digest	SHA-384, algorithm -43, with a 48-byte output [11]
Key identification	Protected SHA-384 x5t, label 34, and unprotected leaf-first x5chain, label 33 [12]
Endorsement identification	None; x5chain identifies the verification key and is not an endorsement identifier
Freshness	Exactly one 32-byte eat_nonce, unique for each request
Main token content type	application/eat+cwt [8]

(continued on next page)

(continued from previous page)

Profile item	This profile
Lead measurements	TCG DICE Concise Evidence using CoAP Content-Format 10571 (application/ce+cbor)
Detached evidence claim	CWT cmw claim 299 [13]
Additional claims	Prohibited by the closed CDDL maps in this profile

Conforming producers MUST emit every choice in the table. Conforming Verifiers MUST support those choices. A producer MUST NOT add claims to `composite-eat-claims` or `detached-claims-set` beyond those permitted by the closed CDDL maps. A Verifier MUST reject a token or detached Claims-Set containing an additional claim.

This is a full EAT profile in the sense of Section 6.2 of [\[2\]](#). The classification applies to decoding, verifying, and checking freshness of the Composite EAT envelope. Native Evidence in claim 299 is claim content whose appraisal is governed by its identified format and Verifier policy. A Verifier MUST NOT produce a successful Attestation Result for a native Evidence item unless it can validate that item locally or delegate validation to a trusted Verifier that supports the identified format and algorithms.

7.3 Bundle Structure

The authoritative artifact is a Detached EAT Bundle with CBOR tag 602. Slot 1 is the signed Composite EAT (`main-token`). Slot 2 is the detached Claims-Set map keyed by Target Environment Identifier. When conveyed with a media type, the bundle MUST use `application/eat-bun+cbor`.

```
composite-bundle = #6.602([
  main-token: bstr .cbor composite-eat,
  detached-claims-sets: {
    + env-id => bstr .cbor detached-claims-set
  }
])

composite-eat = #6.61(#6.18([
  protected:  bstr .cbor protected-headers,
  unprotected: unprotected-headers,
  payload:    bstr .cbor composite-eat-claims,
  signature:  bstr
]))

protected-headers = {
  1:  -35,
  3:  "application/eat+cwt",
  34: certificate-thumbprint
}

certificate-thumbprint = [ -43, bstr .size 48 ]
```

```

unprotected-headers = {
  33: cose-x509-chain
}

cose-x509-chain = bstr / [ 2* bstr ]

```

Every certificate in cose-x509-chain is DER encoded. A chain containing more than one certificate MUST begin with the Lead Attester end-entity certificate. The protected x5t MUST use SHA-384 and equal the SHA-384 digest of the complete DER encoding of that certificate.

A Verifier MUST reject the token if x5t does not match the first certificate in x5chain. It MUST treat every carried certificate as untrusted input and validate a path to a trust anchor configured independently of the bundle, including applicable certificate usage, validity, and revocation checks [14].

7.4 Top-Level Claims

```

composite-eat-claims = {
  10: bstr .size 32,
  265: profile-oid,
  256: bstr .size (7..33),
  273: measurements-type,
  266: submods-type
}

```

The eat_nonce claim contains exactly one nonce. The Verifier MUST generate a new nonce for every request. The same nonce MUST be used to obtain every nonce-capable Sub-Attester evidence item included in the bundle.

Claim 256 contains the Lead Attester uuid and MUST conform to [2].

Claim 265 MUST equal the OCP Composite EAT profile OID approved before final publication. The requested value is not an assigned profile identifier until OCP approves it.

7.5 Lead Attester Self-Measurements

The Lead Attester's local evidence is carried in top-level claim 273, not in submods.

```

measurements-type = [ + lead-attester-concise-evidence ]

lead-attester-concise-evidence = [
  content-format: 10571,
  value: bstr .cbor concise-evidence-map
]

```

This constrains the measurements claim from [2]. Each entry MUST use CoAP Content-Format 10571 (application/ce+cbor) and contain a byte-string-wrapped concise-evidence-map conforming to [15]. This is the same measurement encoding required by the OCP Profile for IETF Entity Attestation Token [16]. The Concise Evidence carried here describes Target Environments measured by the Lead Attester; Sub-Attester Evidence remains detached under submods.

8 Detached Sub-Attester Evidence

8.1 Detached-Submodule-Digest Binding

Every Sub-Attester is represented in the signed token by a Detached-Submodule-Digest. The complete evidence is carried in slot 2 of the bundle under the same Target Environment Identifier.

```
submods-type = { + env-id => detached-submodule-digest }

detached-submodule-digest = [
  hash-alg: -43,
  digest:   bstr .size 48
]

env-id = tstr .size (5..64)
```

For every Target Environment Identifier E, submods[E] MUST equal the SHA-384 digest of detached-claims-sets[E] computed according to [Deterministic Encoding and Digest Rules](#). The key set of submods MUST be identical to the key set of detached-claims-sets. A Verifier MUST reject a bundle containing a missing or unreferenced detached Claims-Set.

8.2 Deterministic Encoding and Digest Rules

Each detached Claims-Set MUST satisfy the core deterministic encoding requirements of Section 4.2.1 of [7]. A Verifier MUST reject a Claims-Set that does not satisfy those requirements.

As required by Section 4.2.18.2 of [2], the digest input is the encoded Claims-Set bytes directly, not the byte-string wrapper used by the bundle and not a textual encoding. SHA-384, COSE algorithm -43, MUST be used for every detached-submodule digest. This algorithm is independent of a measurement hash negotiated by a native protocol.

8.3 Native Evidence Carriage

Each detached Claims-Set contains registered CWT claim 299 (cmw) from [13]. Its value is one CMW Record. The CMW type identifies the native evidence format.

Only the three Record CMW types defined below are permitted. Tag and Collection CMWs, CoAP Content-Format type identifiers, and omission of ind are prohibited.

```
detached-claims-set = {
  299 => native-evidence-cmw
}

native-evidence-cmw = spdm-evidence-cmw /
                      device-eat-cmw /
                      composite-eat-bundle-cmw
```

Each CMW carries the Evidence conceptual-message indicator. Evidence is bit 2 in the RFC 9999 ind bitmap and is encoded as integer 4. CMW is encapsulation, not security protection. A Verifier MUST validate native protection and provenance after validating the detached digest.

8.3.1 SPDM Signed Measurements

```
spdm-evidence-cmw = [
  type: "application/spdm-evidence+cbor",
  value: bstr .cbor spdm-evidence,
  ind: 4
]

spdm-evidence = [
  signed-measurements: bstr,
  cert-chain: bstr,
  ? vca: bstr
]
```

signed-measurements is the binary SPDM SignedMeasurements value. For SPDM 1.2 and later, it includes the negotiated-version, capabilities, and algorithms (VCA) transcript. For SPDM 1.0 and 1.1, it contains only the signed GET_MEASUREMENTS exchange.

cert-chain is the concatenation, in SPDM chain order, of the DER-encoded certificates extracted from the reassembled SPDM certificate chain. It excludes the SPDM Length, Reserved, and RootHash fields and is not PEM encoded.

vca is the observed VCA transcript. It MUST be present for SPDM 1.0 and 1.1 and MUST be absent for SPDM 1.2 and later. See [\[17\]](#).

8.3.2 Device-Emitted EAT

```
device-eat-cmw = [
  type: "application/eat+cwt",
  device-token: bstr,
  ind: 4
]
```

device-token MUST contain the complete CWT-encoded EAT as emitted by the device, without decoding or re-encoding. It MUST cryptographically bind the Verifier nonce. It MUST conform to the OCP Profile for IETF Entity Attestation Token and MUST identify that profile in claim 265. Other registered EAT media types require a revision of this profile.

8.3.3 Recursive Composite EAT

A Sub-Attester that is itself a Lead Attester MAY supply a complete Composite EAT bundle as native evidence.

```
composite-eat-bundle-cmw = [
  type: "application/eat-bun+cbor",
  value: bstr .cbor composite-bundle,
  ind: 4
]
```

The child bundle MUST conform to this profile and MUST bind the same Verifier nonce as its parent. The Verifier MUST recursively perform the validation in [Verification](#). Implementations

SHOULD enforce a deployment-specific maximum nesting depth.

8.3.4 SPDM-Carried TCG DICE Concise Evidence

Signed measurements carrying TCG DICE Concise Evidence [15] use the `spdm-evidence-cmw` schema. The measurement blocks are preserved verbatim. The component performing collection does not need to distinguish ordinary SPDM measurements from blocks carrying TCG DICE Concise Evidence. The Verifier interprets those blocks under the applicable native Evidence profile.

8.3.5 CMW and Digest Boundaries

The CMW is part of the detached Claims-Set. The digest input therefore includes claim key 299, the complete deterministic CMW encoding, its `type` and `ind` fields, and its value byte string.

A conveying protocol MAY additionally carry the complete `composite-bundle` as a CMW typed value. Such an outer wrapper is not part of a detached Claims-Set digest input.

8.4 Target Environment Identifier

The `submods` key and detached Claims-Set map key is a stable Target Environment Identifier, distinct from transport addresses, device UUIDs, and endorsement identifiers. It:

1. is lowercase ASCII;
2. has at least two dot-separated components, with first component `env`;
3. names a reported logical environment, not the device instance; and
4. is between 5 and 64 bytes long.

Examples include `env.nic.0`, `env.gpu.0`, and `env.pcie.4`.

9 Verification (Informative)

A Verifier is expected to perform the following checks before producing an Attestation Result:

1. Decode the bundle, confirm tag 602, and enforce every encoding and algorithm choice in [Profile Conformance](#).
2. Match protected x5t to the end-entity certificate in x5chain, validate the Lead Attester certificate path, and validate the COSE_Sign1 signature.
3. Match eat_nonce to the challenge, match eat_profile to the approved OCP Composite EAT profile identifier, and validate the Lead Attester ueid and measurements.
4. Require identical submods and detached Claims-Set key sets and recompute every digest according to [Deterministic Encoding and Digest Rules](#).
5. Parse each claim-299 CMW, validate its native signature and certificate or token chain, and match its nonce to the challenge.
6. Match the identity proven by each native Evidence item to the identity authorized for its reported Target Environment Identifier by independently trusted composition information.

The Composite EAT signature, matching key sets, and detached digests establish the integrity and freshness of the included platform observation. Digest validation detects replacement of an included detached Claims-Set, and native Evidence validation establishes its Sub-Attester provenance. Determining whether authentic Evidence is associated with the correct logical environment requires independent appraisal.

A Verifier MUST NOT infer platform-inventory completeness solely from the Composite EAT signature or from agreement between the signed submods map and the detached Claims-Set map. A Verifier that determines platform-inventory completeness MUST compare the reported environment set and proven native identities against independently trusted expected-composition information. A platform CoRIM [18] is one possible source. Native measurements are appraised against trusted reference values selected by Verifier policy. This profile does not define endorsement discovery or reference-value appraisal.

10 Security Considerations

The security considerations of [\[19\]](#), [\[9\]](#), [\[12\]](#), [\[2\]](#), [\[13\]](#), and [\[1\]](#) apply.

10.1 Native Evidence Protection

Native signatures remain end-to-end verifiable because evidence is carried verbatim and pinned by a signed digest. A Verifier MUST validate both layers. Accepting the Composite EAT signature without validating native evidence would incorrectly treat collection-component-authored bytes as Sub-Attester-authored Evidence.

Each native Evidence item MUST independently prove binding to the same nonce. A Verifier MUST reject an item whose nonce is absent, unverifiable, or does not match the challenge.

The fixed ES384 and SHA-384 choices prevent algorithm substitution at the Composite EAT layer. For SPDm 1.0 and 1.1, the separately carried VCA transcript is not covered by the responder's measurement signature. A deployment requiring cryptographic binding of negotiated SPDm parameters MUST require SPDm 1.2 or later in appraisal policy.

10.2 Lead Attester Protection

The Lead Attester signing key and sources of `ueid` and top-level measurements MUST be protected from untrusted software performing Evidence collection or bundle assembly. The `ueid` MUST follow [\[2\]](#) and remain stable for the Lead Attester.

Compromise of the Lead Attester signing key permits forgery of the envelope, nonce, Lead Attester measurements, labels, and evidence digests. It does not permit forgery of an uncompromised Sub-Attester signature but defeats the platform-scoped binding. Verifiers MUST validate the Lead Attester certificate path, revocation state, and authorization policy rather than trusting a chain because it is carried in `x5chain`.

Verifiers MUST perform the certificate-path and protected `x5t` validation specified in [Bundle Structure](#).

10.3 Resource Exhaustion

Detached evidence, certificate chains, recursive bundles, and the number of submodules are attacker-influenced inputs. Implementations SHOULD enforce limits on bundle size, Claims-Set size, certificate-chain length, submodule count, and nesting depth. Verifiers SHOULD validate structure and signed digests before expensive native appraisal, without treating a valid digest as a substitute for native signature validation.

11 Privacy Considerations

A stable Lead Attester `ueid` and end-entity certificate enable correlation. Native device certificates and device-emitted EATs can identify individual Sub-Attesters. Target Environment Identifiers expose topology, and measurements can reveal firmware versions or configuration.

Deployments SHOULD restrict bundle access to authorized Verifiers and use a confidentiality-protected conveying protocol when this information is sensitive. A Verifier SHOULD disclose only the Attestation Result needed by a Relying Party rather than forwarding the bundle. Nonces SHOULD be unpredictable and MUST NOT encode user, account, workload, or other identifying information.

12 IANA Considerations

This specification requests no IANA action. The media type `application/spdm-evidence+cbor` identifies the deterministic CBOR encoding of the `spdm-evidence` structure in [Native Evidence Carriage](#). It is not yet registered; its registration is planned through the IETF Composite EAT specification [\[20\]](#). If the registration is unavailable or differs from this specification, a revision of this specification will select a different media type and profile identifier.

13 Alignment and Change Control

This profile builds on the IETF Composite EAT work [\[20\]](#) and is self-contained: all requirements are defined here. Unlike draft-sun-rats-composite-eat-00, which uses a provisional claim, this profile carries native Evidence as RFC 9999 Record CMWs in CWT claim 299.

The IETF and OCP specifications define separate full EAT profiles. A token identifies exactly one of them through claim 265; it does not identify both. Conformance to this OCP profile is determined by this specification. In particular, when an OCP Composite EAT carries a device-emitted EAT as Sub-Attester Evidence, that EAT MUST conform to the OCP Profile for IETF Entity Attestation Token. Native SPDm Evidence remains permitted and need not be converted to a device EAT. This OCP profile also constrains the Lead Attester's claim 273 measurements to the TCG DICE Concise Evidence encoding used by the OCP Profile for IETF Entity Attestation Token.

This specification requests OID 1.3.6.1.4.1.42623.1.4 for the OCP Composite EAT profile. The request follows the existing OCP Security branch and uses the next child value after the documented .2 and .3 assignments. OCP remains the assignment authority and MUST confirm that the requested child value is available before final publication. The OCP Profile for IETF Entity Attestation Token OID, 1.3.6.1.4.1.42623.1.3, identifies a different full EAT profile and cannot be reused for the Composite EAT main token. After OCP approval, the profile CDDL MUST be narrowed to the exact assigned OID encoding. See [IANA Considerations](#) for the status of application/spdm-evidence+cbor.

Changes to bundle structure, claims, algorithms, native evidence forms, deterministic encoding, digest input, or verification behavior require explicit OCP review. An incompatible change requires a new OCP profile identifier. When the IETF work becomes an RFC, this document SHOULD replace the draft reference with the RFC and document whether any technical differences remain.

14 Acknowledgements

The authors thank the OCP Security Project and IETF RATS reviewers whose feedback shaped the Composite EAT architecture and profile.

Appendix A: Worked Example

This non-normative diagnostic example elides certificates, signatures, and nested token bytes. The requested OID 1.3.6.1.4.1.42623.1.4 is shown only for review of the proposed profile encoding; it remains pending OCP approval. Exact detached Claims-Set vectors follow the diagnostic form.

[illegible]

```

    ]]
  }}
]]
}
})>>
]]
}>>,
h'<Lead Attester ES384 signature>'
]))>>,
{
  "env.nic.0": <<{
    299: [
      "application/spdm-evidence+cbor",
      <<[h'12010000aabbccdd', h'30820100deadbeef']>>,
      4
    ]
  }>>,
  "env.accel.0": <<{
    299: ["application/eat+cwt", h'<device CWT>', 4]
  }>>,
  "env.child.0": <<{
    299: [
      "application/eat-bun+cbor",
      h'<child Composite EAT bundle>',
      4
    ]
  }>>
}
])

```

The deterministic encoding of the complete `env.nic.0` Claims-Set is:

```
a119012b83781e6170706c69636174696f6e2f7370646d2d65766964656e6365\
2b63626f7253824812010000aabbccdd4830820100deadbeef04
```

Its SHA-384 digest is `c322d4b38698e2a652dec5ef6c9158a1f5c654e415870d9a
accd3ae367be72bb5d5260f3433b93502a30fd858fb76746`.

For device-emitted EAT, the synthetic CWT bytes are `d83dd28440a04040`. The deterministic Claims-Set encoding is:

```
a119012b83736170706c69636174696f6e2f6561742b63777448d83dd28440a0\
404004
```

Its SHA-384 digest is `dd4e41442e3bb7b38fc05437cc9dae0b3e7a7188f37c8030
7f5502d5c3e38b96f88c0666707c947a352c092d58974f2c`.

For recursive composition, the synthetic child bundle contains the same CWT bytes and one detached `env.leaf.0` SPDM Claims-Set. The deterministic parent Claims-Set encoding is:

```
a119012b8378186170706c69636174696f6e2f6561742d62756e2b63626f7258\  
55d9025a8248d83dd28440a04040a16a656e762e6c6561662e30583aa119012b\  
83781e6170706c69636174696f6e2f7370646d2d65766964656e63652b63626f\  
7253824812010000aabbccdd4830820100deadbeef0404
```

Its SHA-384 digest is 41a15dc29c5be302be56efcd77a2d63afa7befdacf28115b35afbca6fcab5d0701201ccd9e766246457ba0afaf9e27.

The native evidence values in these vectors are synthetic and are not valid signatures or complete protocol responses. The encodings and digests are exact conformance vectors for the CMW, detached Claims-Set, and digest boundaries.

Appendix B: Collected CDDL

The following CDDL collects the profile grammar. The external concise-evidence-map type is defined by [15] and is required when validating the collected grammar. While the requested OID remains pending, profile-oid accepts the untagged absolute-OID byte string required by [2]. This placeholder MUST NOT be treated as authorization to emit an arbitrary OID. After OCP approves the assignment, it MUST be narrowed to the exact assigned OID encoding.

```
; OCP Composite EAT profile CDDL.
; Requested profile OID: 1.3.6.1.4.1.42623.1.4, pending OCP approval.
; RFC 9711 encodes claim 265 as untagged absolute-OID content. The requested
; value is h'2b0601040182cc7f0104'. The profile-oid value will be fixed after
; approval. This placeholder MUST NOT authorize an arbitrary OID.

composite-bundle = #6.602([
  main-token: bstr .cbor composite-eat,
  detached-claims-sets: {
    + env-id => bstr .cbor detached-claims-set
  }
])

composite-eat = #6.61(#6.18([
  protected: bstr .cbor protected-headers,
  unprotected: unprotected-headers,
  payload: bstr .cbor composite-eat-claims,
  signature: bstr
]))

protected-headers = {
  1: -35,
  3: "application/eat+cwt",
  34: certificate-thumbprint
}

certificate-thumbprint = [ -43, bstr .size 48 ]

unprotected-headers = {
  33: cose-x509-chain
}

cose-x509-chain = bstr / [ 2* bstr ]

composite-eat-claims = {
  10: bstr .size 32,
  265: profile-oid,
  256: bstr .size (7..33),
  273: measurements-type,
  266: submods-type
}

profile-oid = bstr

; concise-evidence-map is defined by the TCG DICE Concise Evidence Binding for
; SPDm specification and is an external CDDL dependency of this profile.
measurements-type = [ + lead-attester-concise-evidence ]

lead-attester-concise-evidence = [
  content-format: 10571,
  value: bstr .cbor concise-evidence-map
]

submods-type = { + env-id => detached-submodule-digest }

detached-submodule-digest = [
  hash-alg: -43,
  digest: bstr .size 48
]
```

```
]
detached-claims-set = {
  299 => native-evidence-cmw
}

native-evidence-cmw = spdm-evidence-cmw /
                      device-eat-cmw /
                      composite-eat-bundle-cmw

spdm-evidence-cmw = [
  type: "application/spdm-evidence+cbor",
  value: bstr .cbor spdm-evidence,
  ind: 4
]

spdm-evidence = [
  signed-measurements: bstr,
  cert-chain: bstr,
  ? vca: bstr
]

device-eat-cmw = [
  type: "application/eat+cwt",
  device-token: bstr,
  ind: 4
]

composite-eat-bundle-cmw = [
  type: "application/eat-bun+cbor",
  value: bstr .cbor composite-bundle,
  ind: 4
]

env-id = tstr .size (5..64)
```

References

- [1] “Remote ATtestation procedureS (RATS) Architecture.” IETF, Jan. 2023. Available: <https://datatracker.ietf.org/doc/html/rfc9334>
- [2] “The Entity Attestation Token (EAT).” IETF, Feb. 2025. Available: <https://datatracker.ietf.org/doc/html/rfc9711>
- [3] “Key words for use in RFCs to Indicate Requirement Levels.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc2119>
- [4] “Ambiguity of Uppercase vs Lowercase in RFC 2119 Key Words.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc8174>
- [5] “Concise Data Definition Language (CDDL): A Notational Convention to Express CBOR and JSON Data Structures.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc8610>
- [6] “Concise Binary Object Representation (CBOR) Tags for Object Identifiers.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9090>
- [7] “Concise Binary Object Representation (CBOR).” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc8949>
- [8] “Entity Attestation Token (EAT) Media Types.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9782>
- [9] “CBOR Object Signing and Encryption (COSE): Structures and Process.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9052>
- [10] “CBOR Object Signing and Encryption (COSE): Initial Algorithms.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9053>
- [11] “CBOR Object Signing and Encryption (COSE): Hash Algorithms.” IETF, Aug. 2022. Available: <https://datatracker.ietf.org/doc/html/rfc9054>
- [12] “CBOR Object Signing and Encryption (COSE): Header Parameters for Carrying and Referencing X.509 Certificates.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9360>
- [13] “The RATS Conceptual Message Wrapper.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc9999>
- [14] “Internet X.509 Public Key Infrastructure Certificate and CRL Profile.” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc5280>
- [15] “DICE Concise Evidence Binding for SPDm.” Trusted Computing Group, Sept. 2025. Available: https://trustedcomputinggroup.org/wp-content/uploads/TCG-DICE-Concise-Evidence-Binding-for-SPDM-V1.1_pub.pdf
- [16] “OCP Profile for IETF Entity Attestation Token, Version 1.0, Section: Concise Evidence.” Open Compute Project. Available: <https://opencomputeproject.github.io/Security/ietf-eat-profile/HEAD/#concise-evidence>
- [17] “Security Protocol and Data Model (SPDM) Specification.” DMTF, Sept. 2024. Available: https://www.dmtf.org/sites/default/files/standards/documents/DSP0274_1.3.2.pdf
- [18] “Concise Reference Integrity Manifest.” IETF, Nov. 2020. Available: <https://datatracker.ietf.org/doc/draft-ietf-rats-corim>
- [19] “CBOR Web Token (CWT).” IETF. Available: <https://datatracker.ietf.org/doc/html/rfc8392>
- [20] “An EAT Profile for Composite Platform Attestation.” IETF, 2026. Available: <https://datatracker.ietf.org/doc/draft-sun-rats-composite-eat/>